Prezime, Ime	JMBAG

Bodovi
/40

Kriptografija i kriptoanaliza — Završni ispit

4. veljače 2022.

1. (2) *Klasična kriptografija.* Šifrirati tekst „ISPIT” Vigenereovom šifrom s ključem „AUTO” ako se koristi sljedeći alfabet s 27 znakova: A B C Č Ć D Đ E F G H I J K L M N O P R S Š T U V Z Ž.

   Rješenje:

Jasni tekst	:	I	S	P	I	T
Ključ	:	A	U	T	O	A (ključ se ponavlja ako ima premali broj znakova)
Šifra	:	I	N	K	B	T

   Npr. za drugi znak jasnog teksta S (ako brojimo znakove od nule, to je znak s rednim brojem 20) zbrojimo s drugim znakom ključa U (23) i računamo modulo 27: $(20 + 23) \mod 27 = 16$ (što je slovo N).

   Odgovor: „INKBT”.

2. (2) *Diferencijalna kriptoanaliza.*

   (a) (1) Koliko ulaznih, a koliko izlaznih razlika treba uzeti u obzir u postupku diferencijalne kriptoanalize jedne supstitucijske tablice kriptosustava DES koja na ulazu ima 6-bitni podatak, a na izlazu 4-bitni podatak?

   $2^6 = 64$ ulaznih razlika i $2^4 = 16$ izlaznih razlika.

   (b) (1) Koliko različitih izlaznih razlika je moguće dobiti u postupku kriptoanalize supstitucijske tablice kriptosustava AES koja na ulazu i na izlazu ima 8-bitni podatak ako nema razlike na ulazu, tj. ulazna razlika je 0?

   Samo je jedna moguća izlazna razlika i to 0 jer za jednake ulaze dobivamo jednak izlaz.

3. (5) *Kriptosustav RSA.* Pretpostavimo da je riječ o kriptosustavu RSA bez nadopunjavanja i sažetka, s javnim ključem $pk = (5, 91)$ i privatnim ključem $sk = (29, 91)$.

   (a) (1) $\varphi(N) = \varphi(55) = \varphi(7 * 13) = (7 - 1) * (13 - 1) = 72.$

   (b) (1) Pokažite da je par (sk, pk) javnog i privatnog ključa korektan.

   $5 * 29 = 145 = 1 + 144 = 1 + 2 * 72 = 1 \mod \varphi(N).$

   (c) (1) Odredite enkripciju poruke (broja) 5. $5^5 = 3125 \mod 91 = 31.$

   (d) (2) Odredite dekripciju poruke (broja) 2 koristeći algoritam uzastopnog kvadriranja. Obavezno navesti postupak.
   Rješenje: $27 = 16 + 8 + 4 + 1 = (11101)_2$

i	4	3	2	1	0
$a[i]$	1	1	1	0	1
d	2	8	37	4	**32**

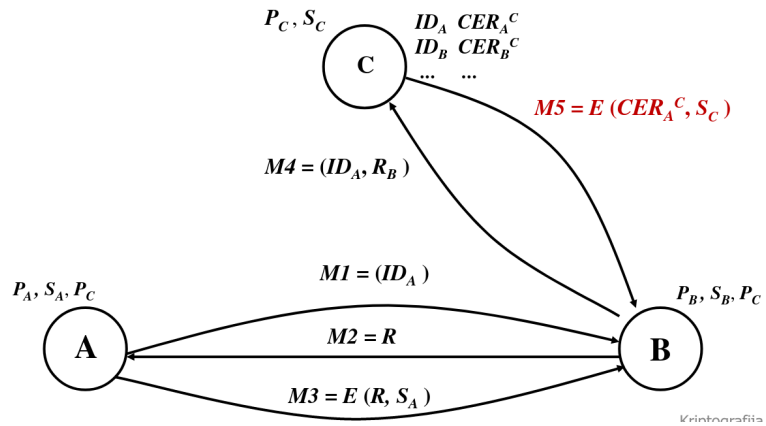
4. (8) *Digitalni potpis i PKI.*

   (a) (1) Koristimo RSA sustav digitalnog potpisa s parom ključeva (e, N), (d, N), kriptografskom funkcijom sažetka H i funkcijom nadopunjavanja P. Kako se točno računa digitalni potpis poruke m?
   $P(H(m))^d \mod N$

   (b) (2) Na primjeru detaljno objasnite zašto RSA sustav digitalnog potpisa nije siguran ako koristimo funkciju sažetka H koja nije otporna na kolizije.
   Ako funkcija nije otporna na kolizije onda napadač može pronaći dvije poruke m_1 i m_2 za koje vrijedi $H(m_1) = H(m_2)$. Sada napadač može zatražiti potpis poruke m_1, a dobiveni potpis je ujedno i potpis poruke m_2 što narušava svojstvo sigurnosti digitalnih potpisa.

(c) (2) Koja sigurnosna svojstva zadovoljava digitalna omotnica, a koja digitalni pečat?
Digitalna omotnica: tajnost; Digitalni pečat: autentičnost, integritet, tajnost, neporecivost.

(d) (3) Skicirajte protokol jednostrane autentifikacije uz pomoć certifikata te navedite sadržaj svih poruka i značenje svih simbola koje koristite.



ID_A : idenifikator sudionika A,
R : nonce,
E : enkripcija,
R : nonce,
S_X, P_X : privatni i javni ključ sudionika X,
R_B : kod kojim se zahtjeva CA certifikat sudionika B,
CER_A^C : certifikat sudionika A od strane certifikacijskog centra C,

5. (6) *Unaprijedna sigurnost.*

(a) (1) Navedite što to znači da protokol razmjene ključeva pruža svojstvo unaprijedne sigurnosti (perfect forward secrecy).
Protokol pruža svojstvo unaprijedne sigurnoti ako kompromis dugotrajnih privatnih ključeva sudionika ne povlači kompromis ključeva prethodno snimljenih sjednica

(b) (2) Detaljno objasnite zašto varijanta TLS protokola u kojoj se koristi RSA za razmjenu ključeva ne pruža navedeno svojstvo unaprijedne sigurnosti.
U toj varijanti protokola, ključ sjednice se generira na temelju nonce vrijednosti (koje napadač vidi) te pms-a koji klijent šalje šifriranog dugotrajnim RSA ključem (napadač vidi $RSA(pms, pk_server)$). Ako napadač snimi sjednicu i kasnije kompromitira privatni ključ onda može odrediti pms te generirati ključ za tu sjednicu.

(c) (3) Navedite varijantu TLS protokola koja pruža svojstvo unaprijedne sigurnosti te skicirajte dvije najvažnije poruke prilikom uspostave ključeva.
Privremeni Diffie-Hellman. Sever šalje klijentu: $(g^x, sig(g^x, sk_server), Cert_server)$. Klijent odgovara s g^y.

6. (5) *Diffie-Hellman i ElGamal.*

(a) (1) Diffie-Hellmanovu razmjenu ključeva u grupi G veličine q s generatorom g smatramo sigurnom ako vrijedi (**zaokružite jedan odgovor**): (a) Teško je rastaviti broj q na proste faktore; (b) Teško je u grupi G računati diskretne logaritme po bazi g; (c) q je velik prost broj; (d) Red elementa g u grupi G je velik prost broj; (e) Broj q i red elementa g su veliki prosti brojevi.
Rješenje: (b)

(b) (1) Navedite *computational Diffie-Hellman* pretpostavku.
Neka je G ciklička grupa reda q, g generator od G te $a, b \in \{0, \ldots, q-1\}$ nasumično odabrani. Napadač za dane (g, g^a, g^b) ne može odrediti g^{ab}.

(c) (3) Pretpostavimo da se obična ElGamal enkripcija koristi za internet aukciju: ponudu od m kuna za predmet aukcije kriptiramo i tako dobiveni skriveni tekst c pošaljemo zajedno s privremenim javnim ključem Y. Ako napadač modificira skriveni tekst tako da je jednak $100 * c$ (umjesto c), hoće li to utjecati na ponudu koju smo poslali? Detaljno obrazložite.
Da, ponuda će biti sto puta veca: $k = Y^a$, $m = 100 * c * k^{-1} = 100 * (m * k) * k^{-1} = 100 * m$

7. (6) *Kriptografija prilagođena uređajima s ograničenim mogućnostima, kvantna i postkvantna kriptografija.*

(a) (2) Navesti što je sve ulaz, a što je sve izlaz autentifikacijskom algoritmu ASCON.
Ulaz = jasni tekst P, povezani ili autentifikacijski podaci A, simetrični ključ K, inicijalizacijski vektor IV i nounce N; **Izlaz** = kriptirani tekst C i autentifikacijska oznaka TAG

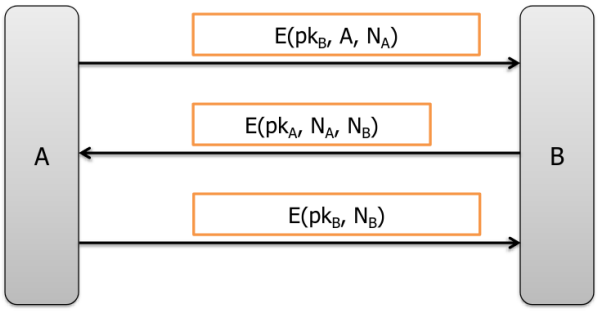
(b) (2) Opisati prvu poruku koju šalje Ana Branku u protokolu BB84. Opisati kanal u kojem se šalje ta poruka.
Odgovor na prvo pitanje: poruka se sastoji od niza nasumično generiranih bitova koji su kodirani koristeći dvije vrste polarizacije koje se također nasumično biraju za svaki bit. **Odgovor na drugo pitanje**: ta se poruka šalje sigurnim kanalom kao što je primjerice optički kabel ili zrakom ako je omogućena optička vidljivost).

(c) (1) **Zaokružiti** moguće funkcionalnosti kriptografskih algoritama u NIST-ovom natječaju postkvantne kriptografije: (a) simetrično kriptiranje; (b) hash; (c) razmjena ključeva; (d) digitalna omotnica; (e) digitalni potpis; (f) digitalni pečat; (g) autentifikacijsko kriptiranje.
Odgovor: (b), (d) i (f).

(d) (1) Što određuje, odnosno što normira kriptografska norma PKCS#11?
Programsko sučelje za rad s kriptografskim tokenima tj. strukture podataka i kriptografske funkcije za rad s kriptografskim uređajima.

8. (6) *Protokoli.* Razmatramo verziju *Needham-Schroeder* protokola s tri poruke kojemu je cilj međusobna autentifikacija sudionika.

(a) (2) Skicirajte protokol.



(b) (3) Ovaj protokol je ranjiv na *men-in-the-middle* napad koji počinje tako da napadač E uvjeri sudionika A da s njim započne sjednicu (A pošalje E poruku $A \to E : \{N_A, A\}_{pub_E}$), a zatim se E lažno predstavi sudioniku B. Detaljno opišite ostatak napada i navedite sve poruke koje su razmijenjene između sudionika i napadača.
Napadač I prvo uvjeri sudionika A da započne sesiju sa njim, a zatim inicira sesiju sa sudionikom B kojeg uvjeri da komunicira sa A.

$$
\begin{aligned}
&A \to I : \{N_A, A\}_{pub_I} \\
&I \to B : \{N_A, A\}_{pub_B} \\
&B \to I : \{N_A, N_B\}_{pub_A} \\
&I \to A : \{N_A, N_B\}_{pub_A} \\
&A \to I : \{N_B\}_{pub_I} \\
&I \to B : \{N_B\}_{pub_B}
\end{aligned}
$$

(c) (1) Kako biste modificirali protokol tako da spriječite navedeni napad? Zašto takva modifikacija sprječava napad?

Modificirali bi drugu poruku tako da je jednaka $\{N_A, N_B, B\}_{pub_A}$.